

Cirque Corporation

Password Policy

Document ID: IS-CIRQ-P-042-G

Category: Information Security

Division: Global

Type: Policy

Version: 1.0

Effective Date: 2026-03-02

Review Date: 2027-03-02

Approved By: Chris Wren, CISO

Generated: March 02, 2026

1. Purpose

This Password Policy establishes requirements for creating, managing, and protecting passwords and authentication credentials used to access Cirque Corporation's information systems, applications, and data.

The purpose of this policy is to:

- Protect company information and systems from unauthorized access
- Establish consistent password requirements across all systems
- Reduce the risk of password compromise and credential theft
- Comply with security frameworks and regulatory requirements (SOC 2, ISO 27001, GDPR, CCPA)
- Promote security best practices among all users
- Support multi-factor authentication implementation

2. Scope

This policy applies to all authentication credentials used to access Cirque Corporation systems, including:

Systems and Applications:

- Network authentication (Active Directory, Azure AD)

- Operating systems (Windows, macOS, Linux)
- Database systems (SQL Server, MySQL, PostgreSQL)
- Business applications (ERP, CRM, email, collaboration tools)
- Cloud services and SaaS applications
- VPN and remote access systems
- Administrative and privileged accounts
- Service accounts and API credentials

Personnel:

- All employees (full-time, part-time, temporary)
- Contractors and consultants
- Third-party vendors with system access
- System administrators and privileged users
- Service accounts and automated processes

This policy applies to both company-issued and personal devices when used to access company systems or data.

3. Password Requirements

All passwords must meet the following minimum requirements:

Standard User Accounts:

- Minimum length: 12 characters
- Must contain at least three of the following:
 - Uppercase letters (A-Z)
 - Lowercase letters (a-z)
 - Numbers (0-9)
 - Special characters (!@#\$%^&*()_+~`{|}~;:~<~>~?)
- Cannot contain user's name, username, or company name
- Cannot be a common dictionary word or easily guessed phrase
- Cannot be identical to previous 12 passwords
- Must be changed every 90 days

Privileged/Administrative Accounts:

- Minimum length: 16 characters
- Must contain all four character types (uppercase, lowercase, numbers, special characters)
- Cannot be identical to previous 24 passwords
- Must be changed every 60 days
- Additional restrictions on dictionary words and patterns

Service Accounts and API Keys:

- Minimum length: 32 characters (random generated recommended)
- Must use cryptographically secure random generation
- Stored encrypted in approved password vault
- Rotated according to service requirements (minimum annually)
- Access logged and monitored

Passphrase Alternative:

- Minimum 4 random words with spaces or separators
- Minimum total length of 20 characters
- Allowed for standard user accounts only
- Must not be common phrases or song lyrics

4. Password Creation Guidelines

Users should follow these guidelines when creating passwords:

Strong Password Examples:

- Use password generators for complex passwords
- Create passphrases using random unrelated words (correct-horse-battery-staple)
- Use sentence-based passwords (1L0v3!Hik1ng&Camp1ng2026)
- Mix character types throughout the password, not just at beginning/end

Prohibited Passwords:

- Password, Welcome, Admin, or variations
- Company name or product names
- User's name, birthday, or personal information

- Sequential characters (12345, abcde, qwerty)
- Repeated characters (aaaa, 1111)
- Simple substitutions (P@ssw0rd)
- Common words from dictionary
- Previously compromised passwords (checked against breach databases)

Best Practices:

- Use unique passwords for each system
- Use a password manager to store complex passwords
- Generate passwords using approved password managers
- Avoid writing passwords down (use password manager instead)
- If temporary note needed, destroy immediately after use
- Change default passwords immediately
- Test password strength before implementation

5. Password Protection

Users must protect passwords according to these requirements:

Security Requirements:

- Never share passwords with anyone, including IT staff or management
- Never reveal passwords in emails, chat messages, or verbal communications
- Never write passwords on sticky notes, whiteboards, or documents
- Store passwords only in approved password management systems
- Do not save passwords in web browsers unless company-approved browser
- Encrypt any files containing passwords
- Never include passwords in support tickets or help requests

Authentication Security:

- Always log out or lock screen when leaving workstation unattended
- Enable automatic screen lock after 10 minutes of inactivity
- Never save passwords on shared or public computers
- Use "private browsing" mode on shared devices

- Clear browser auto-fill credentials on personal devices
- Protect password reset questions and backup codes

Suspicious Activity:

- Report suspected password compromise immediately
- Change password immediately if compromise suspected
- Report phishing attempts requesting credentials
- Be suspicious of any request for password disclosure
- Verify system prompts before entering credentials

6. Multi-Factor Authentication (MFA)

Multi-factor authentication is required for enhanced security:

MFA Required For:

- All remote access (VPN, remote desktop)
- Email systems (Office 365, Gmail)
- Cloud services and SaaS applications
- Administrative and privileged accounts
- Financial systems and payment processing
- Access to confidential or regulated data
- Password reset and account recovery processes

Approved MFA Methods (in order of preference):

1. Hardware security keys (YubiKey, Titan Security Key)
2. Authenticator apps (Microsoft Authenticator, Google Authenticator, Duo)
3. Push notifications to registered mobile devices
4. Time-based one-time passwords (TOTP)
5. SMS codes (least preferred, use only if no other option)

MFA Security:

- Register multiple MFA devices for backup access
- Securely store backup codes in password manager
- Never share MFA codes with anyone

- Report lost or stolen MFA devices immediately
- Approve MFA prompts only for sessions you initiated
- Be suspicious of unexpected MFA requests (may indicate compromise)

MFA Restrictions:

- Voice calls not approved for MFA
- Email-based OTP not approved (email may be compromised)
- SMS should be last resort due to SIM swapping risks

7. Password Management Systems

Approved password management solutions must be used:

Approved Password Managers:

- Enterprise: Microsoft Azure AD Password Protection
- Team Password Managers: 1Password Business, LastPass Enterprise
- Individual: 1Password, Bitwarden, LastPass (personal accounts discouraged)
- IT-Managed: CyberArk, HashiCorp Vault (for service accounts)

Password Manager Requirements:

- Must use strong master password (20+ characters)
- Must enable MFA for password manager access
- Must use password manager's secure password generator
- Must not share password manager accounts
- Must keep password manager app updated
- Must enable auto-lock after period of inactivity

Organizational Requirements:

- IT maintains enterprise password manager for shared credentials
- Service account passwords stored in centralized vault
- Emergency access procedures documented
- Password vault regularly backed up
- Access to password vault logged and monitored
- Password manager approved by IT Security before use

8. Password Change Requirements

Passwords must be changed according to these schedules:

Regular Password Changes:

- Standard user accounts: Every 90 days
- Privileged/administrative accounts: Every 60 days
- Service accounts: Annually or per service requirements
- Shared administrative passwords: Every 30 days
- Default passwords: Immediately upon receipt

Mandatory Immediate Change:

- Suspected or confirmed password compromise
- Security incident involving authentication systems
- Employee termination (all shared passwords)
- Contractor access termination
- Following security assessment findings
- After system administrator changes
- Shared password accessed by departing team member

Password Expiration:

- Users notified 14 days before password expires
- Grace period: 5 days after expiration
- Account disabled after grace period until password reset
- Cannot reuse previous 12 passwords (standard accounts)
- Cannot reuse previous 24 passwords (privileged accounts)

Temporary Passwords:

- Issued for new accounts or password resets
- Must be changed at first login
- Valid for 24 hours only
- Cannot be reused as permanent password
- Require additional verification for issuance

9. Password Reset Procedures

Password resets must follow secure procedures:

Self-Service Password Reset:

- Available through approved self-service portal
- Requires MFA or security questions for verification
- Must verify identity through multiple factors
- Email notification sent after password reset
- Administrator notified of excessive reset attempts

IT Help Desk Password Reset:

- User must verify identity (employee ID, personal information)
- For sensitive accounts, require manager approval
- Temporary password issued valid for 24 hours
- Must be changed at first login
- Reset request logged with user identification details
- For administrators, require additional verification

Security Questions:

- Minimum 3 security questions required
- Answers must not be easily researched or guessed
- Cannot use answers available on social media
- Questions reset if suspected compromise
- Excessive failed attempts trigger account lock

Account Lockout:

- Account locked after 5 failed login attempts
- 30-minute automatic lockout period
- Additional verification required for manual unlock
- Pattern of lockouts investigated for potential attack
- Service accounts exempt from automatic lockout (monitored instead)

10. System Administrator Responsibilities

System administrators must implement and enforce password policies:

Technical Controls:

- Configure systems to enforce password complexity requirements
- Enable password history to prevent reuse
- Implement password expiration and age requirements
- Configure account lockout after failed attempts
- Enable MFA for all administrative functions
- Deploy password protection services (Azure AD Password Protection)
- Monitor for use of compromised or banned passwords

Password Storage:

- All passwords must be stored using strong cryptographic hashing
- Use industry-standard algorithms (bcrypt, PBKDF2, Argon2)
- Never store passwords in plain text or reversibly encrypted
- Protect password hashes with same security as passwords themselves
- Ensure database backups containing hashes are encrypted
- Service passwords stored in encrypted vaults only

Monitoring and Auditing:

- Log all authentication attempts and failures
- Monitor for brute force attacks and credential stuffing
- Alert on unusual authentication patterns
- Review authentication logs regularly
- Investigate account lockouts and failed logins
- Report suspicious activity to security team

Default Password Management:

- Change all default passwords before system deployment
- Document default password changes in system configuration
- Maintain inventory of systems requiring password changes

- Verify default passwords changed during security audits

11. Service Account and Automated Process Passwords

Service accounts require special password management:

Service Account Requirements:

- Minimum 32-character random generated passwords
- Stored in enterprise password vault (CyberArk, HashiCorp Vault)
- Access to service passwords restricted to authorized personnel
- Service password changes coordinated with application teams
- Password rotation schedule documented
- Service accounts identified and inventoried

Service Account Security:

- Service accounts do not use MFA (by necessity)
- Enhanced monitoring and alerting for service account activity
- Service accounts restricted to specific systems and functions
- No interactive login allowed for service accounts
- Service accounts granted minimum necessary permissions
- Separate service account for each application/service

API Keys and Tokens:

- Treated with same security as passwords
- Generated using cryptographically secure methods
- Rotated according to application requirements
- Stored encrypted in secure storage
- Access logged and monitored
- Revoked immediately when no longer needed

Automation Security:

- Credentials never hard-coded in scripts or configuration files
- Use approved credential management systems for automation
- Credentials retrieved dynamically at runtime

- Log all automated credential access
- Regular review of automated process permissions

12. Shared and Emergency Access Passwords

Shared passwords require additional controls:

Shared Account Management:

- Shared accounts minimized and approved by management
- Shared passwords stored in password vault with audit trail
- Access to shared passwords logged with user identity
- Shared passwords rotated monthly minimum
- Usage of shared accounts monitored and reviewed
- Business justification required for shared accounts

Emergency Access:

- Emergency access procedures documented
- Break-glass accounts secured in password vault
- Emergency account access triggers immediate alert
- All emergency access usage reviewed by CISO
- Emergency passwords changed after each use
- Regular testing of emergency access procedures

Privileged Access Management (PAM):

- Check-in/check-out system for privileged credentials
- Session recording for privileged access
- Automatic password rotation after privileged session
- Time-limited access to privileged accounts
- Approval workflow for privileged access requests
- Different credentials used for standard vs. privileged activities

13. Third-Party and Vendor Access

Third-party access requires specific password controls:

Vendor Account Management:

- Separate accounts created for each vendor/contractor
- Vendor accounts clearly identifiable
- Access granted only to necessary systems
- All vendor accounts require MFA
- Vendor passwords meet same requirements as internal users
- Vendor access reviewed quarterly

Vendor Password Requirements:

- Cannot share accounts between vendor personnel
- Each vendor user must have unique credentials
- Vendor passwords changed when vendor personnel change
- Vendor access automatically expires after contract end
- Vendor accounts disabled after 30 days of inactivity
- Vendor must acknowledge password policy compliance

Vendor Access Monitoring:

- Enhanced logging for all vendor account activity
- Regular review of vendor account usage
- Immediate notification of suspicious vendor activity
- Vendor access sessions time-limited when possible
- Regular attestation of vendor account necessity

14. Password Policy Exceptions

Exceptions to this policy require formal approval:

Exception Request Process:

- Written justification documenting business need
- Risk assessment of exception impact
- Compensating controls to mitigate risk
- Approval by CISO required
- Documented exception period (not indefinite)

- Regular review of active exceptions

Valid Exception Scenarios:

- Legacy systems unable to support password requirements
- Third-party systems with vendor-controlled authentication
- Technical limitations preventing policy compliance
- Regulatory requirements superseding policy
- Emergency situations (temporary only)

Compensating Controls:

- Enhanced monitoring and alerting
- Network segmentation and access restrictions
- Additional authentication factors
- Increased audit frequency
- Reduced password lifetime
- Isolated network access

Exception Documentation:

- Exception register maintained by IT Security
- Quarterly review of all active exceptions
- Annual recertification of exceptions
- Plan to remediate and eliminate exceptions
- Management awareness of exception risks

15. Training and Awareness

All users must receive password security training:

Required Training:

- Password security training during onboarding
- Annual password security refresher
- Phishing awareness including credential theft
- Password manager usage training
- MFA enrollment and usage

- Incident reporting procedures

Training Topics:

- Creating strong passwords and passphrases
- Password manager benefits and usage
- Multi-factor authentication importance
- Recognizing phishing and credential theft attempts
- Password sharing risks
- Social engineering tactics
- Incident reporting procedures
- Legal and compliance implications

Awareness Activities:

- Regular security awareness communications
- Phishing simulation exercises
- Password security tips in internal communications
- Security awareness month campaigns
- Gamification and security challenges
- Posters and visual reminders
- Executive communication on security importance

Privileged User Training:

- Additional training for system administrators
- Privileged access management system training
- Secure credential handling procedures
- Incident response for credential compromise
- Compliance and audit requirements

16. Monitoring, Compliance, and Enforcement

Password policy compliance is monitored and enforced:

Monitoring Activities:

- Automated password policy compliance scanning

- Regular authentication log review
- Failed login attempt monitoring
- Account lockout pattern analysis
- Privileged account activity monitoring
- Password age and expiration tracking
- Compromised password detection

Compliance Verification:

- Quarterly password policy compliance audits
- Annual penetration testing including password attacks
- Password hash analysis for weak passwords
- Review of password policy exceptions
- Verification of technical controls effectiveness
- User compliance sampling and testing

Audit Requirements:

- Authentication logs retained for 1 year minimum
- Password policy changes documented and approved
- Exception documentation maintained
- Incident reports related to passwords retained
- Training completion records maintained
- Compliance audit findings tracked to resolution

Policy Violations:

- Password sharing: Written warning to termination
- Using weak or compromised passwords: Mandatory training and warning
- Failure to change expired password: Account suspension
- Writing down passwords: Counseling and training
- Sharing credentials with unauthorized parties: Immediate termination
- Circumventing password controls: Termination and possible legal action

Incident Response:

- Credential compromise triggers incident response
- Immediate password reset for affected accounts
- Investigation of compromise method
- Communication to affected users
- Lessons learned and policy updates
- Reporting to management and compliance teams

17. Policy Review and Updates

This policy is reviewed and updated regularly:

Review Schedule:

- Annual policy review by IT Security and CISO
- Review after significant security incidents
- Review following audit findings
- Review when technology changes affect requirements
- Review for alignment with industry standards

Update Process:

- Draft changes reviewed by stakeholders
- Impact assessment of policy changes
- Management approval of policy updates
- Communication of changes to all users
- Training updated to reflect policy changes
- Technical controls updated to enforce new requirements

Industry Alignment:

- NIST password guidelines compliance
- SOC 2 Trust Services Criteria alignment
- ISO 27001 requirements
- GDPR and data protection regulations
- Industry-specific requirements (PCI-DSS, HIPAA)

Continuous Improvement:

- Feedback from users and administrators
- Review of emerging threats and attack techniques
- Evaluation of new authentication technologies
- Password policy effectiveness metrics
- Benchmarking against industry practices